

MATRIZ DE PLANEJAMENTO

FISC./ANO: 60/2024

JURISDICIONADO: PMRF - PREFEITURA RIO DAS FLORES; PMRC - PREFEITURA RIO CLARO; PMRB - PREFEITURA RIO BONITO; PMR - PREFEITURA RESENDE; PMQ - PREFEITURA QUISSAMA; PMQ - PREFEITURA QUEIMADOS; PMQ - PREFEITURA QUATIS; PMPR - PREFEITURA PORTO REAL; PMP - PREFEITURA PORCIUNCULA; PMP - PREFEITURA PINHEIRAL; PMRO - PREFEITURA RIO DAS OSTRAS; PMP - PREFEITURA PETROPOLIS; PMPA - PREFEITURA PATY DO ALFERES; PMP - PREFEITURA PARATY; PMPS - PREFEITURA PARAIBA DO SUL; PMP - PREFEITURA PARACAMBI; PMNI - PREFEITURA NOVA IGUAÇU; PMNF - PREFEITURA NOVA FRIBURGO; PMN - PREFEITURA NITEROI; PMP - PREFEITURA PIRAI; PMSMM - PREFEITURA SANTA MARIA MADALENA; PMSF - PREFEITURA SAO FIDELIS; PMN - PREFEITURA NATIVIDADE; PMVR - PREFEITURA VOLTA REDONDA; PMV - PREFEITURA VASSOURAS; PMVS - PREFEITURA VARRE-SAI; PMV - PREFEITURA VALENÇA; PMTR - PREFEITURA TRES RIOS; PMTM - PREFEITURA TRAJANO DE MORAES; PMT - PREFEITURA TERESOPOLIS; PMT - PREFEITURA TANGUA; PMSG - PREFEITURA SÃO GONÇALO; PMSAP - PREFEITURA SANTO ANTONIO DE PADUA; PMSJ - PREFEITURA SILVA JARDIM; PMS - PREFEITURA SAQUAREMA; PMS - PREFEITURA SAPUCAIA; PMSSA - PREFEITURA SAO SEBASTIAO DO ALTO; PMSPA - PREFEITURA SAO PEDRO DA ALDEIA; PMSJVRP - PREFEITURA SAO JOSE DO VALE DO RIO PRETO; PMSJU - PREFEITURA SAO JOSE DE UBA; PMSJM - PREFEITURA SAO JOAO DE MERITI; PMSJB - PREFEITURA SAO JOAO DA BARRA; PMSFI - PREFEITURA SAO FRANCISCO DE ITABAPOANA; PMS - PREFEITURA SEROPEDICA; PMS - PREFEITURA MUN SUMIDOURO; PMN - PREFEITURA NILOPOLIS; PMMP - PREFEITURA MIGUEL PEREIRA; PMM - PREFEITURA MIRACEMA; PMC - PREFEITURA CARMO; PMCM - PREFEITURA CARDOSO MOREIRA; PMC - PREFEITURA CARAPEBUS; PMC - PREFEITURA CANTAGALO; PMCG - PREFEITURA CAMPOS DOS GOYTACAZES; PMC - PREFEITURA CAMBUCI; PMCM - PREFEITURA CACHOEIRAS DE MACACU; PMCF - PREFEITURA CABO FRIO; PMCLG - PREFEITURA COMENDADOR LEVY GASPARIAN; PMBJI - PREFEITURA BOM JESUS DO ITABAPOANA; PMBR - PREFEITURA BELFORD ROXO; PMBM - PREFEITURA BARRA MANSA; PMBP - PREFEITURA BARRA DO PIRAI; PMAC - PREFEITURA ARRAIAL DO CABO; PMAB - PREFEITURA ARMAÇÃO DOS BÚZIOS; PMA - PREFEITURA AREAL; PMA - PREFEITURA ARARUAMA; PMA - PREFEITURA APERIBE; PMAR - PREFEITURA ANGRÁ DOS REIS; PMBJ - PREFEITURA BOM JARDIM; PMCM - PREFEITURA CONCEIÇÃO DE MACABU; PMCA - PREFEITURA CASIMIRO DE ABREU; PMDB - PREFEITURA DUAS BARRAS; PMM - PREFEITURA MESQUITA; PMM - PREFEITURA MENDES; PMM - PREFEITURA MARICA; PMM - PREFEITURA MANGARATIBA; PMM - PREFEITURA MAGE; PMM - PREFEITURA MACUCO; PMC - PREFEITURA CORDEIRO; PMLM - PREFEITURA LAJE DO MURIAE; PMJ - PREFEITURA JAPERI; PMM - PREFEITURA MACAE; PMI - PREFEITURA ITAPERUNA; PMI - PREFEITURA ITATIAIA; PMEPP - PREFEITURA ENGENHEIRO PAULO DE FRONTIN; PMG - PREFEITURA GUAPIMIRIM; PMIG - PREFEITURA IGUABA GRANDE; PMDC - PREFEITURA DUQUE DE CAXIAS; PMI - PREFEITURA ITAGUAI; PMI - PREFEITURA ITALVA; PMI - PREFEITURA ITAOCARA; PMI - PREFEITURA ITABORAI.

OBJETIVO DA AUDITORIA: Verificar a conformidade das prefeituras municipais jurisdicionadas à Lei 13.709/2018 (Lei Geral de Proteção aos Dados – LGPD), por meio de auditoria realizada em conjunto com o TCU e outros tribunais de contas no âmbito da Rede Integrar.

ID	QUESTÃO DE AUDITORIA	INFORMAÇÕES REQUERIDAS	FONTES DE INFORMAÇÃO	PROCEDIMENTO DE AUDITORIA	POSSÍVEIS ACHADOS
1	Preparação, Contexto, Liderança e Capacitação As organizações se estruturaram para a condução de medidas de adequação à LGPD?	1. Atividades de preparação, contexto, liderança e capacitação relacionadas à LGPD; 2. Política de segurança da informação; 3. Políticas/normas sobre a classificação de informações (classificação da informação é boa prática abrangente que envolve não apenas os graus de sigilo da LAI, mas também outras classificações em função de leis como a LGPD); 4. Política de proteção de dados; 5. Plano de projeto/ação para adequação à LGPD; 6. Normativos, além da LGPD, que abrangem a proteção de dados pessoais; 7. Atos de nomeação do DPO; 8. Dados de identificação do DPO; 9. Plano de treinamento.	1. Questionário; 2. Documentos enviados como evidências às respostas do questionário.	Preparação 1. Verificar se as organizações instituíram projeto, plano de ação ou iniciativa similar para providenciar a adequação à LGPD; 2. Verificar se as organizações publicaram normativos que consideram aspectos gerais sobre o tratamento de dados pessoais; 3. Verificar se as organizações mapearam seus principais processos de tratamento de dados pessoais; 4. Verificar se as organizações possuem programa de governança em privacidade de dados implementado, periodicamente monitorado/avaliado e atualizado continuamente. Liderança	1. As organizações não definiram um plano de ação e medidas para adequação à LGPD; 2. As organizações não possuem políticas que buscam assegurar a proteção de dados pessoais; 3. As organizações não designaram um DPO; 4. As organizações não identificaram e avaliaram em seu ambiente interno aspectos relacionados à LGPD; 5. As organizações não possuem iniciativas para conscientização e capacitação em LGPD.



TRIBUNAL DE CONTAS DO ESTADO DO RIO DE JANEIRO
SECRETARIA GERAL DE CONTROLE EXTERNO
SUBSECRETARIA DE CONTROLE DE POLÍTICAS DE CIDADANIA
COORDENADORIA DE AUDITORIA EM POLÍTICAS DE TECNOLOGIA DA INFORMAÇÃO

ID	QUESTÃO DE AUDITORIA	INFORMAÇÕES REQUERIDAS	FONTES DE INFORMAÇÃO	PROCEDIMENTO DE AUDITORIA	POSSÍVEIS ACHADOS
				1. Verificar se há política de segurança da informação. 2. Verificar se há política de classificação da informação; 3. Verificar se a política de classificação da informação abrange a categorização de dados pessoais; 4. Verificar se a política de classificação da informação contempla diretrizes quanto à identificação de dados pessoais sensíveis; 5. Verificar se a política contempla diretrizes quanto à identificação de dados de crianças e adolescente; 6. Verificar se há política de proteção de dados; 7. Verificar se as organizações indicaram o encarregado (DPO) para atuar como canal de comunicação entre o controlador, os titulares dos dados e a Autoridade Nacional	

ID	QUESTÃO DE AUDITORIA	INFORMAÇÕES REQUERIDAS	FONTES DE INFORMAÇÃO	PROCEDIMENTO DE AUDITORIA	POSSÍVEIS ACHADOS
				de Proteção de Dados (ANPD); 8. Verificar se as informações do DPO são publicadas em local de fácil acesso. Contexto 1. Verificar se foram identificados outros normativos que abrangem comandos que remetam à proteção de dados pessoais e que também devem ser seguidos pelas organizações; 2. Verificar se as organizações identificaram as principais partes interessadas relacionadas à proteção de dados pessoais; 3. Verificar se foram identificados os instrumentos contratuais firmados com operadores e controladores;	

ID	QUESTÃO DE AUDITORIA	INFORMAÇÕES REQUERIDAS	FONTES DE INFORMAÇÃO	PROCEDIMENTO DE AUDITORIA	POSSÍVEIS ACHADOS
				4. Verificar se foram identificados os dados pessoais que são tratados pelas organizações, bem como os processos que realizam esses tratamentos; 5. Verificar se foram identificados os locais de armazenamento de dados pessoais da organização; 6. Verificar se foram identificados os riscos associados ao tratamento de dados pessoais. Capacitação Verificar se as organizações possuem iniciativas para conscientização e capacitação de servidores em proteção de dados pessoais.	
2	Conformidade do tratamento; Direitos do titular; Compartilhamento de dados; Violação de	1. Atividades e aspectos de conformidade de tratamento de dados pessoais, direitos do titular relacionadas,	1. Questionário. 2. Documentos enviados como evidências às	Conformidade do tratamento	1. As organizações não analisaram a conformidade dos processos que realizam

ID	QUESTÃO DE AUDITORIA	INFORMAÇÕES REQUERIDAS	FONTES DE INFORMAÇÃO	PROCEDIMENTO DE AUDITORIA	POSSÍVEIS ACHADOS
	dados pessoais; e Medidas de proteção. As organizações desenvolveram medidas e controles de proteção de dados pessoais para adequação à LGPD?	compartilhamento de dados pessoais, violação de dados pessoais e medidas de proteção relacionadas à LGPD; 2. Inventário de dados pessoais; 3. Fluxogramas; 4. Registro de atividades de tratamento de dados pessoais; 5. Relatórios de impacto de proteção de dados; 6. Ajustes e contratos firmados com operadores; 7. Ajustes e contratos firmados com controladores conjuntos; 8. Política de privacidade; 9. Sistema de Gestão de Requisições; 10. Sistema de Gestão de Incidentes; 11. Plano de gestão de riscos; 12. Relatórios de Impacto de Proteção de Dados (RIPD).	respostas do questionário.	1. Verificar se a organização identificou que os processos que realizam tratamento de dados pessoais estão em conformidade com os princípios da finalidade e da necessidade (minimização e tempo de retenção) estabelecidos na LGPD; 2. Verificar se há base legal definida que justifique os tratamentos de dados pessoais; 3. Verificar se possui inventário de dados pessoais; 4. Verificar se os dados pessoais e os processos de tratamento estão consolidados em um registro de atividades de tratamento de dados pessoais. 5. Verificar se as organizações produzem Relatórios	tratamento de dados pessoais; 2. As organizações não possuem um registro de atividades de tratamento de dados pessoais; 3. As organizações não identificaram dados pessoais compartilhados com terceiros; 4. As transferências internacionais de dados pessoais podem não estar em conformidade com a LGPD; 5. As organizações não publicaram a política de privacidade; 6. As organizações não possuem mecanismos para atendimento dos direitos dos titulares; 7. As organizações não possuem processo definido para tratamento de violações de dados pessoais; 8. As organizações não possuem processo definido para notificação dos interessados no caso de violação de dados pessoais; 9. As organizações não adotam, ou adotam de maneira insuficiente, medidas de segurança, técnicas e administrativas,

ID	QUESTÃO DE AUDITORIA	INFORMAÇÕES REQUERIDAS	FONTES DE INFORMAÇÃO	PROCEDIMENTO DE AUDITORIA	POSSÍVEIS ACHADOS
				de Impacto de Proteção de Dados (RIPD); 6. Verificar se foram implementados controles para tratamento dos riscos identificados no RIPD. Compartilhamento de dados 1. Verificar se a organização realizou a identificação e avaliação dos dados pessoais compartilhados com terceiros; 2. Verificar se a organização mantém registro dos eventos relacionados aos compartilhamentos de dados pessoais; 3. Verificar se a organização identificou a existência de transferência internacional de dados pessoais; 4. No caso de transferência	para proteger os dados pessoais; 10. As organizações não tratam os riscos associados ao tratamento de dados pessoais; 11. As organizações não tomaram providências para que os tratamentos de dados pessoais ocorram <i>by design</i> e <i>by default</i>.

ID	QUESTÃO DE AUDITORIA	INFORMAÇÕES REQUERIDAS	FONTES DE INFORMAÇÃO	PROCEDIMENTO DE AUDITORIA	POSSÍVEIS ACHADOS
				internacional de dados, verificar se foram observados os critérios estabelecidos na LGPD. Direitos do Titular 1. Verificar se há política de privacidade; 2. Verificar se a política de privacidade está publicada em local de fácil acesso; 3. Verificar se há meios para requisição e atendimento dos direitos dos titulares de dados pessoais; Violação de dados pessoais 1. Verificar se há Plano de resposta a incidentes de segurança da informação que envolvem dados pessoais; 2. Verificar se há meios para registro (inclusive pelos próprios titulares) e para resposta a incidentes	

ID	QUESTÃO DE AUDITORIA	INFORMAÇÕES REQUERIDAS	FONTES DE INFORMAÇÃO	PROCEDIMENTO DE AUDITORIA	POSSÍVEIS ACHADOS
				de segurança da informação que envolvem violação de dados pessoais; 3. Verificar se há procedimento definido para notificar o titular e a ANPD quando houver a ocorrência de incidente de segurança que possa acarretar risco ou dano relevante aos titulares. Medidas de proteção 1. Verificar se as organizações adotam medidas de segurança, técnicas (soluções de segurança, controle de acesso) e administrativas (medidas organizacionais), para proteger os dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas de destruição, perda, alteração,	

ID	QUESTÃO DE AUDITORIA	INFORMAÇÕES REQUERIDAS	FONTES DE INFORMAÇÃO	PROCEDIMENTO DE AUDITORIA	POSSÍVEIS ACHADOS
				comunicação ou qualquer forma de tratamento inadequado ou ilícito; 2. Verificar se existe um processo formal de registro, cancelamento e provisionamento de acesso de usuários a sistemas que realizam tratamento de dados pessoais; 3. Verificar se há rastreabilidade (<i>logs</i>) dos tratamentos de dados efetuados; 4. Verificar se é utilizada criptografia para proteger os dados pessoais sensíveis. 5. Verificar se as organizações tomaram providências para que processos e sistemas sejam projetados (desde a concepção) de forma que a coleta e o tratamento de dados pessoais estejam limitados ao que é estritamente necessário para o	



ID	QUESTÃO DE AUDITORIA	INFORMAÇÕES REQUERIDAS	FONTES DE INFORMAÇÃO	PROCEDIMENTO DE AUDITORIA	POSSÍVEIS ACHADOS
				propósito identificado (<i>Privacy by design e Privacy by default</i>).	

Equipe de Auditoria:

AUGUSTO CESAR BENVENUTO DE ALMEIDA - 02/004823

EMANUELLI PAQUINI CAMPOS - 02/004825

FÁBIO SOUZA LIMA - 02/004822

JOÃO PAULO DE FREITAS RAMIREZ - 02/004820

Supervisor:

BRUNO MATTOS SOUZA DE SOUZA MELO - 02/004258

